HimVeda by Pahadi Roots — Enterprise Readiness & Change Verification Report

Date: 3 Nov 2026 · **Prepared for:** independent verification (Fable 5.1) · **Production:** https://www.pahadiroots.com · **Admin:** https://pahadi-admin.vercel.app **Storefront repo:** `chambailsudhir/pahadiroots-next` (Next.js 16, App Router, Supabase, Razorpay live, Resend, Vercel Hobby, region `bom1`) **Admin repo:** `chambailsudhir/pahadi-admin` · **DB:** Supabase project `ulyrhnpoiypuvaurlqqi` **State when written:** storefront `main` = `9776e66` (#138, live — `/api/health` returns `9776e66`); admin `main` = `5a7a3c8` (#25, live). **Local gates on that commit:** `tsc --noEmit` clean · `vitest`: 309 files passed, 3 175 tests passed, 7 skipped · `eslint`: 0 errors, 8 warnings. Admin repo: 222 test files / 3 343 tests passed at #25.

> **How to read this report.** Every item lists *what was wrong*, *what was changed*, *where*, and *how to verify it independently*. Items are tagged **[S]** = done in this working session, **[P]** = merged by a parallel Claude session during the same days (listed so the verifier sees the whole picture; I did not re-derive their reasoning, only that they are on `main` and tests pass). Nothing here is a claim of "perfect": section 9 lists what is *not* verified or still open.

---

1. Executive summary

Area	Verdict	Evidence
Cart → checkout → payment → confirmation (COD + online)	**Working end to end on production**	Real ₹2 online orders captured and verified (ORD-2026-00128, 00129, 00138, 00171); COD orders 00174, 00179, 00182 etc.
Order e-mails (customer + owner, COD + paid + cancelled)	**Rebuilt, delivered, visually verified in Gmail**	Screenshots from the owner; DB markers `paid_email_*_sent`, DLQ = 0
Status e-mails from admin (packed/shipped/out-for-delivery/delivered/cancelled)	**Rebuilt today with the real logo** (admin #25, deployed)	Rendered locally; owner to confirm in Gmail by changing a test order's status
GST / invoice parity	Rebuilt; on-page invoice = downloadable invoice	Unit tests + DB trigger `set_order_gst_split`; **needs CA sign-off (§9)**
Security hardening	Many findings closed (CSP nonce, CSRF, IDOR, session revocation, rate limits)	See §4.5

Area	Verdict	Evidence
Performance (cart/checkout/upsell/LCP)	Measurably faster; CLS 0	§4.6
Accessibility / contrast	Public pages axe-clean except one decorative watermark	§4.7
Operations readiness	**Soft-launch ready**; items in §9 are business tasks (mailbox, legal, test-data cleanup)	§9

Recommendation: go live as a controlled launch. Preconditions: deactivate the `Test` product (id 28, still `is_active=true` at time of writing), clear or exclude test orders (ORD-2026-00170 … 00187), and keep the first-week watch list in §10.

---

2. Architecture touched (for orientation)

- **Order creation:** `POST /api/v1/orders` (COD only) → `createOrder()` in `src/lib/services/orderService.ts` (DB RPC `create_order_with_items`, idempotency key, stock decrement by DB trigger, GST split by trigger `set_order_gst_split`).
- **Online payment:** `POST /api/v1/payments` (`create_payment`, `verify_payment`) + Razorpay webhook `POST /api/v1/webhook/razorpay` (HMAC). Both converge on `runPaidSideEffects()` in `src/lib/server/orderPayments.ts`.
- **E-mail:** Resend via `sendTransactionalEmail()` (`src/lib/server/email.ts`) with dead-letter table `failed_emails` + cron retry. Customer template `src/lib/server/orderEmail.ts`; owner template `src/lib/server/adminOrderEmail.ts` (new); shared brand header `src/lib/server/emailShell.ts` (real logo `public/email-logo.png`).
- **Admin app** (separate repo) sends status e-mails via `/api/admin` action `send_status_email` → now `src/lib/statusEmail.js`.
- **Per-email idempotency:** markers in `order_events` (`paid_email_customer_sent`, `paid_email_admin_sent`, `payment_verified` with `emails_tracked:true`).

---

3. Production proof collected (not just unit tests)

Check	Result
Real online payments (₹2 each)	ORD-2026-00128 (delivered), 00129 (delivered → refunded), 00138 (confirmed), **00171 (confirmed, paid 3 Nov)**. Each has a captured `payments` row, `payment_captured_webhook` + `payment_verified`; 00171 also has

Check	Result
	`paid_email_admin_sent` (16:26:07) and `paid_email_customer_sent` (16:26:08), `emails_tracked:true`, 0 failed e-mails.
COD orders	00170, 00172, 00173, 00174, 00179, 00182, 00187 created; 00182 cancelled by customer (stock restored, cancelled e-mail sent).
Owner e-mail (new template)	ORD-2026-00182 e-mail received with logo, banner, "What to do", customer, address, items. DB: `order_origin` event "Delhi, DL, IN · Desktop (Chrome, Windows)".
Status e-mails (old template)	Owner supplied screenshots of Packed/Shipped/Out-for-delivery/Delivered /Cancelled for 00174/00182 showing the **old** leaf-emoji header and overlapping photo — this is what admin #25 replaced.
Smoke (3 Nov 18:21 UTC)	`/`, `/products`, `/cart`, `/checkout`, `/track`, `/contact`, `/policies/{privacy,returns,shipping,terms}`, `/sitemap.xml`, `/robots.txt`, `/api/health` → all 200, 0.2–2.7 s. `failed_emails` pending in last 24 h = 0.
Tamper test	Client price/amount manipulation on `create_payment/orders` → server recomputes; amount comes from DB (Playwright `tamper.js`).

4. Work done — by theme

4.1 Checkout, cart, order confirmation [S unless noted]

#	Problem	Fix (file)	Verify
C1	Server did not enforce `min_order_amount`; stock error did not name the product	`orderService.ts`: server-side min check, product-named stock error	`orderService.*` tests; place a cart below minimum → 4xx with message
C2	COD max when setting was NaN → no cap	`orderService.ts` fallback 3000	`useCheckoutPage.codCap` test
C3	Verify failure left the customer on checkout	`useCheckoutPage.ts` → routes to order page	`pendingVerify` test

#	Problem	Fix (file)	Verify
C4	Razorpay `checkout.js` (~70 requests) loaded for every checkout visitor, slowing page	`CheckoutClient.tsx`: `<Script>` rendered only after "Pay online" chosen (**PR #128**)	`razorpayLoadFailed` test; Network tab on `/checkout` shows no `checkout.razorpay.com` until online chosen
C5	Quantity-limit mismatch (UI allowed what API rejected)	`src/lib/cartLimits.ts` `MAX_LINE_QTY=50` used by store, revalidate, zod (**#127**)	`cartStore` tests; set qty 51 → clamped
C6	Coupon preview ignored category rules; coupon hints empty in prod	`pricingService.ts`, `couponLines.ts`, schemas (#123 [P-adjacent])	`couponLines` tests
C7	Confirmation page had its own nav/footer, hero without h1, fake rating, CSS bleed, wrong courier URLs, GA4 double-fire, no refunded view	`order-success/page.tsx` rewrite, `:where(.oc-scope)` scoping	axe on `/order-success`; unit tests; GA4 age gate 24 h
C8	Own abandoned online order blocked the customer's COD/online retry	`releaseOwnAbandonedOnlineOrders` (#108 [P])	`orders` route test
C9	Cart "order summary" appeared late; upsell rail slow	`CartSettingsSeed` server-seeded settings (#121), upsells from cached `getStoreData()` (#122)	Cart page paints summary with first render; `cartUpsellsRoute` tests
C10	Guest "Loading saved details" never cleared	(#75)	`useCheckoutPage` tests
C11	Phone: stepper wider than screen; iOS zoom on inputs	(#73, #76)	Playwright at 375 px
C12	Coupon: one use per person **and** per	(#74) + DB v27 (coupon released on	`coupon` tests; DB trigger

#	Problem	Fix (file)	Verify
	delivery address (incl. guests)	cancel/payment_failed by any writer, #126 [P])	

4.2 E-mails [S]

#	Problem	Fix	Verify
E1	Online-paid customers got a 5-line note with no items	`buildOrderEmail()` — one itemised, photo-bearing template for COD **and** paid (status headline, progress, lines, price breakdown with explicit *Round off*, GST-included note, address, payment, WhatsApp help)	`orderEmail.test.ts`; owner screenshot of ORD-2026-00171
E2	Paid e-mail read non-existent `customers.is_guest`; recipient wrong for guests colliding with accounts	Recipient = order snapshot e-mail (`shipping_address.email`) first; account = `auth_user_id != null`	`paidOrderEmail.test.ts`
E3	Duplicate / lost e-mails on retries	Per-e-mail markers written **only after** Resend accepted (sent or dead-lettered); webhook re-drives only when `emails_tracked` and a marker is missing, >90 s after paid; legacy orders never re-mailed (`orderPayments.ts`, `webhook/razorpay/route.ts`)	`webhookRazorpay` tests; DB `order_events` for 00171
E4	**Owner never got a paid-order e-mail; COD owner e-mail was 5 lines**	`adminNotifyAddress()` (setting → `ADMIN_EMAIL` env fallback;	`adminOrderEmail.test.ts`; screenshot of 00182; `order_origin`

#	Problem	Fix	Verify
		`site_settings` has no row). New `adminOrderEmail.ts`: banner, "What to do", customer (tel/WhatsApp links, account/guest, order history), address, itemised lines with SKU, price breakdown (coupon code, coins, shipping, COD fee, GST, round-off), payment, placed-from (city + device, **no IP stored**), "Open order in admin" deep link. Used for COD, paid and cancelled (**#133, #135**)	event in DB. Old one-liner remains only as fallback if the order can't be read
E5	Admin deep link	admin **#24**: `/admin/orders?q=<order no>` and `?order=<id>` prefill search; a single exact match opens the panel	`orders-deep-link.real.test.tsx`
E6	Admin status e-mails: old leaf-emoji gradient header, flex layout (photo over name), invisible header in Outlook, button → non-existent `/order-confirmation` route	admin **#25**: `src/lib/statusEmail.js` (extracted for tests); real logo header, table layout, solid button, link `https://www.pahadiroots.com/track?order=<no>`; abandoned-cart mail header also fixed; escaping done once	`statusEmailBrand.test.js`; rendered screenshot; **owner to confirm live by changing a test order's status**
E7	Verify button / header invisible in Outlook	#129 [P] (table shell, `emailSafeHtml`)	tests; rendering
E8	Brand header	#130 [P]: one	all customer mails

#	Problem	Fix	Verify
	mismatch across mails	`brandHeaderRow()` ; returns bullet dropped from confirmation	share header
E9	Coins promised to guests	Coins only when `signedIn/authenticatedCustomerId` (orders route, paid path) — **note:** coin rules later changed by parallel sessions (#132/#137/#138: paid on delivery, 1 per ₹200 min 1 max 5). Verify e-mail/checkout copy matches the *current* rule.	grep `coinsEarned` in `orderEmail.ts` vs DB v31 function

4.3 Reviews & review-request e-mail [S + P]

- Verified-purchase reviews (migration **v23**, applied) + review-request mail (#96 [P-rebased by S]).
- Burst bug found live after applying v23 (10 mails in 4 s) → `review_request_enabled=false` temporarily; fixed with window `REVIEW_REQUEST_WINDOW_DAYS=14`, `DEFAULT_LIMIT=5`, one per customer per run, `REVIEW_REQUEST_COOLDOWN_DAYS=7`, skip inactive products/orders with returns, product photo/name/size shown (#98, #100, #114). Re-enabled.
- Verify: `reviewRequests.test.ts`; review page shows product image/variant.

4.4 Invoice, GST, pricing [S + P]

- Downloadable invoice (`/api/orders/[id]/invoice`) now a full tax invoice (HSN, place of supply, seller GSTIN/address, CGST/SGST or IGST, legacy COD label) and **matches the on-page invoice** via the shared `computeOrderInvoice` (#70, #123, S work in `order-success`, `lookup` route).
- GST after discounts (#68); shipping + COD fee GST at the goods' rate (#132 [P]); stored order tax includes fee GST (**migration v29**, #134 [P], applied; v30 follow-up applied).
- Order e-mail "Subtotal = item sum + explicit Round off" (#95).
- **Verify:** pick 3 orders (COD with coupon, paid, with coins) and reconcile `orders.total_amount = subtotal − coupon − coins value + shipping + cod_surcharge ± round_off`, and `cgst+sgst(+igst) = tax`. **Requires CA sign-off (§9).**

4.5 Security [mostly P, some S]

CSP nonce on checkout/account and all per-request routes (#45, #63); chat API hardening + proof-of-work (#28, #63); sign-up no longer returns a profile for an existing e-mail (ACC-060, #82); PKCE-bound Google sign-in, recovery-only reset, session revocation, shared rate limits (#88, #107); rotated refresh cookies on every response (#105); per-user API answers `private, no-store` (#101); private bucket for return photos (#72); no back-office/cost columns in public payloads (#14, #113); RLS/privilege revocations (migrations `revoke_anon_*`, v22); COD abuse caps per phone/IP (#111); non-JSON body → 400 (#103, S); Razorpay webhook budget + currency check (#104); sign-up verification link has no token in URL (#116); wishlist ownership (#87, #117). **Verify:** run `get_advisors` (security) on Supabase; test CSP with `curl -I` on `/checkout`.

4.6 Performance [S + P]

Checkout lazy Razorpay (#128); cart summary seeded (#121); upsell from cache (#122); LCP work (#22–24, #41, #63–65); sticky mobile filter bar with product count (#114); no per-navigation DB stampede (#109); Vercel Hobby usage controls (#115, #119/#120: `scripts/vercel-ignore.sh` skips preview builds and docs-only changes). **Verify:** Lighthouse mobile on `/`, `/products`, `/cart`, `/checkout`; Vercel usage dashboard. Measured here: pages 0.2–2.7 s TTFB-to-complete on curl; CLS 0 in Playwright.

4.7 Accessibility / UI [S + P]

Stone-grey palette darkened to AA in `tailwind.config.ts`; policy links underlined; 24 px slider thumbs; focus management of cart drawer (#56–60); chat FAB smaller and fades while scrolling on phones (`public/js/ai-assistant.js`, #118); confirmation-page CSS regression (`:where()` scoping) found by live axe and fixed with a test; icons instead of emoji (#34, #52, #61); axe-core sweep: all public pages clean except decorative watermark words on `/our-stories`.

4.8 Catalogue, SEO, content [S + P]

Only categories with products in menu/footer (`getPopulatedCategoryIds`); chat prompt uses live catalogue facts (`chatStoreFacts.ts`, stale 14-product list removed); no health claims in copy/chatbot (#42); titles without doubled brand (#97, #125); Merchant feed, ItemList JSON-LD, sitemap fixes (#10, #11, #30, #123); `/contact` shows real settings and relays 400/429 reasons; `/track?order=` prefill with phone normalisation.

4.9 Account, returns, referral, loyalty [P mostly]

Account deletion keeps only invoice data (#91, #67); returns vs DB index, replaced-return terminal (v24, #99); referral programme with abuse controls (#71, v17/v21/v26); loyalty reversal on cancel (v16/v19); coins now earned on **delivery** (v28, #132) and **by order value** (v31, #138); phone-ownership verification via inbound WhatsApp (#92, v25) **feature-flagged OFF** (needs `WHATSAPP_VERIFY_NUMBER`, `WHATSAPP_APP_SECRET`, `WHATSAPP_VERIFY_TOKEN`).

4.10 DB migrations applied to production (Supabase `list_migrations` confirms)

`v17, v18, v19, v20, v21, v22, v23 (reviews_verified_purchase), v24, v25, v26, v27, v28, v29, v29b, v30, v31`. Verify each file in repo root `db_migration_v*.sql` matches the applied name; rollback tests exist for v21/v25/v26/v27.

4.11 Infrastructure

- `ADMIN_EMAIL` env (Vercel, prod/preview/dev) set to `chambail.sudhir@gmail.com` (interim until own mail domain). Env change only applies on a new build → forced by comment-only PR #131 (the redeploy was skipped by `vercel-ignore.sh` because code was unchanged — by design).
- Vercel retention set to 1 week by owner; Hobby limits watched.

---

5. Test evidence

- Storefront: 3 175 passing unit/integration tests (vitest), TypeScript strict clean, ESLint 0 errors. CI job `verify` (compile check + tests + lint) must be green to merge (enforced by me before each squash-merge).
- Admin: 3 343 passing tests.
- Browser: Playwright scripts (axe, CLS, tamper, Razorpay lazy-load, order flows) were run against production during the session; scripts live in the session scratchpad, not the repo.
- **Not covered by automated tests:** real inbox rendering in Outlook desktop / Apple Mail (only Gmail web screenshots seen); load testing; real-device Safari/Android matrix.

---

6. Suggested independent verification plan (for Fable 5.1)

1. **Read the diff by theme**, not by PR: `git log --oneline main` and the PR list in §8; for each §4 item open the named file.
2. **Money correctness (highest risk):** `src/lib/services/orderService.ts` (`calcPriceSummary`, coupon, loyalty clamp), `src/lib/server/orderPayments.ts`, `src/app/api/v1/payments/route.ts`, `src/app/api/v1/webhook/razorpay/route.ts`. Questions: can a client alter the charged amount? can a payment be bound to the wrong order? are double-captures refunded/flagged? is the webhook idempotent under retries and out-of-order delivery?
3. **E-mail idempotency:** simulate webhook + verify racing; confirm exactly one customer and one owner e-mail; confirm DLQ path and cron `retry-failed-emails`.
4. **Template safety:** every dynamic value escaped once (customer: `orderEmail.ts`; owner: `adminOrderEmail.ts`; admin: `statusEmail.js` — inputs are escaped in `buildStatusEmail`, builder must not escape again).
5. **DB:** run Supabase security + performance advisors; review triggers `set_order_gst_split`, stock triggers, v27–v31 functions for race conditions; confirm RLS on `orders`, `customers`, `order_events`, `failed_emails`, `payments`.
6. **GST arithmetic** on sample orders (§4.4).

7. **UX smoke on a phone** and in Outlook: checkout both ways, cancel, track, invoice download, status e-mails after changing a test order's status in admin.
8. **Fresh-eyes review of parallel-session work [P]** (coins rules, GST-on-fees, v28–v31, auth/session changes) — these changed money and identity logic and deserve the most scrutiny.

---

7. Suggested verifier prompt (copy/paste)

> You are auditing an e-commerce site (Next.js 16 + Supabase + Razorpay live + Resend, Vercel Hobby) before an enterprise-grade launch. Read `docs/ENTERPRISE_READINESS_REPORT_2026-11-03.md`, then verify each numbered item against the code at the commits named, run `npm ci && npx tsc --noEmit && npx vitest run && npm run lint`, and report: (a) items confirmed fixed, (b) items only partially fixed, (c) regressions or new risks introduced by the changes, (d) money/identity/security issues ranked by severity with file:line and a failing test or reproduction, (e) anything in §9 that blocks launch. Do not trust the report's claims — re-derive them from code and the production database (read-only).

---

8. Change index (merged PRs relevant to this period)

Storefront: #1–#138 on `main` (see `git log`). Attribution below is best-effort from the session log (verify authorship with `git log --format='%h %an %s'` if it matters). Mostly this session: #80, #81, #83, #94–#95, #97–#98, #100–#103, #106, #114, #118, #121–#123, #125, #127, #128, #131, #133, #135. Parallel sessions (incl. #108, #112): #92, #96, #99, #104, #105, #107, #109, #111, #113, #115–#117, #119–#120, #124, #126, #129–#130, #132, #134, #136–#138. **Admin:** #24 (orders deep links), #25 (status e-mails: logo/table layout/working link); earlier #14–#23 (analytics/finance audits, uploads). **Open PR:** storefront #110 (superseded; contents included in #114) — can be closed by the owner.

---

9. Not verified / still open (honest list)

Blocking before "enterprise" claims 1. **`Test` product (id 28, ₹2) is `is_active=true`** — any customer can buy it. Deactivate. 2. **Test orders in production DB** (ORD-2026-00170 … 00187, several SHIPPED/CONFIRMED, phone 9717255662 shows "67 orders / ₹19,973 spent"). They distort owner e-mail "History", dashboards and finance. Cancel/soft-delete with stock/finance implications reviewed (`016_cleanup_test_orders.sql` exists in admin repo as a pattern). 3. **Legal/tax review not done:** GST invoice layout (HSN, place of supply, fee GST), data-deletion retention wording, marketing claims ("100% Natural", "Lab reports"), refund-window wording. Needs a CA/lawyer.

Operational 4. Owner e-mails go to an interim Gmail (`ADMIN_EMAIL`); no business mailbox; `hello@` mailbox not set up. Customers replying to `noreply@` get nothing. 5. WhatsApp phone-verification flag is **off**; Meta Business setup + 3 env vars required. 6.

`site_settings.admin_notify_email` row does not exist (env fallback in use). 7. ORD-2026-00108 should be reconciled in the Razorpay dashboard; `failed_emails` contains old `example.com` test rows; ₹2 test payments (00171, 00138, …) are real money in Razorpay. 8. Admin status e-mail new template **not yet seen in an inbox** (deployed 18:02 UTC; verified by local render only). 9. Coin rules were changed by parallel sessions late in the day (on delivery, 1 per ₹200, min 1, max 5): re-verify checkout/e-mail/account copy and the v28–v31 SQL for edge cases (partial returns, cancel after delivery, COD vs paid).

Platform limits / risks 10. Vercel **Hobby** plan: ISR-write, deployment-storage and CPU budgets; single region `bom1`. Enterprise load/SLA needs Pro + monitoring/alerting. 11. No load/stress test performed; no synthetic uptime monitor documented. 12. Outlook desktop / Apple Mail renderings unverified (table-based, so low risk). 13. Real-device matrix (iOS Safari, low-end Android) not exercised. 14. GraphQL is blocked in the CI sandbox, so PR bookkeeping used REST; irrelevant to production.

---

10. First-week watch list after go-live

- Every order: owner e-mail arrives; customer e-mail arrives; `failed_emails` (status ≠ sent) stays 0; `order_events` has both `paid_email_*` markers for online orders.
- Reconcile Razorpay dashboard vs `payments` daily (captured − refunded).
- Vercel usage (ISR writes, build minutes) after the 1-week retention change.
- Review-request e-mails: ≤ 5 per run, ≤ 1 per customer per 7 days.
- Support inbox/WhatsApp for “no e-mail received”, “coins missing”, “invoice wrong”.
- Re-run axe + Lighthouse weekly on `/`, `/products`, `/cart`, `/checkout`.